

OASIS INFOBYTE

RESEARCH REPORT

Common Network Security Threats: DoS, Man-in-the-Middle, and Spoofing Attacks

*A Study of Threat Mechanisms, Real-World Incidents,
and Layered Mitigation Strategies*

Author	Muhammad Aryan Tariq
Program	Cyber Security
Organization	Oasis InfoByte
Research Area	Network Security
Date	June 2026

TABLE OF CONTENTS

Abstract..... 3

1. Introduction..... 3

2. Denial-of-Service (DoS) and DDoS Attacks..... 4

 2.1 Definition and Mechanism 4

 2.2 Real-World Example: The Mirai Botnet and the Dyn DNS Attack (2016) 4

 2.3 Recent Escalation (2024–2025 Data)..... 5

 2.4 Impact 5

 2.5 Mitigation Strategies..... 6

3. Man-in-the-Middle (MITM) Attacks..... 7

 3.1 Definition and Mechanism 7

 3.2 ARP Spoofing as a Foundational MITM Technique 7

 3.3 Impact 8

 3.4 Mitigation Strategies..... 8

4. Spoofing Attacks 9

 4.1 IP Spoofing..... 9

 4.2 ARP Spoofing..... 9

 4.3 DNS Spoofing (DNS Cache Poisoning) 9

 4.4 Mitigation Strategies for Spoofing 10

5. Comparative Analysis..... 11

6. General Best Practices for Network Security..... 11

7. Conclusion 13

8. References..... 14

Abstract

Modern networks face a continuously evolving threat landscape in which availability, confidentiality, and integrity are routinely tested by adversaries ranging from individual hobbyists to organized criminal syndicates and state-sponsored actors. This report presents a structured, evidence-based examination of three foundational categories of network security threats: Denial-of-Service (DoS) and Distributed Denial-of-Service (DDoS) attacks, Man-in-the-Middle (MITM) attacks, and spoofing attacks (IP, ARP, and DNS spoofing).

For each threat category, the report explains the underlying mechanism, analyzes real-world incidents, evaluates organizational and technical impact, and surveys current mitigation strategies and industry standards, including NIST guidance and DNSSEC. The report draws on a combination of academic literature, vendor threat-intelligence reports, and primary historical records of major incidents such as the 2016 Mirai/Dyn attack and the record-setting Cloudflare-mitigated DDoS campaigns of 2025.

The report concludes that no single technical control is sufficient; rather, resilient network security depends on layered defense, combining cryptographic authentication, traffic monitoring, redundancy, and user awareness.

1. Introduction

Computer networks form the backbone of virtually every modern institution, from universities and hospitals to banks and government agencies. As dependence on networked systems has grown, so too has the incentive for malicious actors to disrupt, intercept, or impersonate network traffic for financial gain, political motive, or competitive advantage.

According to industry telemetry, attack volumes have continued to climb sharply: Cloudflare alone reported that distributed denial-of-service attack volume **grew by 58% year-over-year and 31% quarter-over-quarter by the end of 2025**, with automated systems mitigating an average of over 5,000 attacks every hour [1].

This report focuses on three threat categories that, while technically distinct, are frequently combined in real-world attack chains:

- Denial-of-Service (DoS/DDoS) attacks, which target the availability of network resources.
- Man-in-the-Middle (MITM) attacks, which target the confidentiality and integrity of communications by secretly intercepting traffic between two parties.
- Spoofing attacks (IP, ARP, and DNS spoofing), which exploit the lack of built-in authentication in foundational network protocols and frequently serve as the enabling technique for both DoS and MITM attacks.

The objective of this report is to provide a conceptually rigorous yet practically grounded understanding of how these attacks function, what damage they have caused historically, and what defensive architectures are recommended by current industry and government standards.

2. Denial-of-Service (DoS) and DDoS Attacks

2.1 Definition and Mechanism

A **Denial-of-Service (DoS) attack** is a deliberate attempt to make a computing resource — a server, application, or network link — unavailable to its legitimate users by overwhelming it with illegitimate traffic or exploiting a flaw that causes it to crash [2]. A DoS attack originates from a *single source*. A **Distributed Denial-of-Service (DDoS) attack** is the same goal pursued from *many distributed sources simultaneously*, typically through a botnet of compromised devices, which makes the attack far harder to mitigate because traffic cannot be blocked by simply filtering one IP address [3].

DoS/DDoS attacks are generally classified into three layers of the OSI model:

Category	OSI Layer	Mechanism	Example Techniques
Volumetric attacks	Network/Transport (L3/L4)	Saturate available bandwidth	UDP flood, ICMP flood, DNS amplification
Protocol attacks	Transport (L4)	Exhaust connection-state tables on servers/firewalls	SYN flood, Ping of Death, Smurf attack
Application-layer attacks	Application (L7)	Exhaust application resources with legitimate-looking requests	HTTP flood, Slowloris, API abuse

A classic example is the **SYN flood**: the attacker sends a large number of TCP SYN (synchronize) packets to a target but never completes the three-way handshake by acknowledging the server's SYN-ACK response. The server allocates memory for each half-open connection while waiting, and once its connection table is exhausted, it can no longer accept legitimate connections [4].

2.2 Real-World Example: The Mirai Botnet and the Dyn DNS Attack (2016)

The most frequently cited case study in DDoS literature is the **Mirai botnet attack on Dyn**, a major DNS provider, on **21 October 2016**. The Mirai malware scanned the internet for Internet of Things (IoT) devices — routers, IP cameras, and digital video recorders — that were still using factory-default

usernames and passwords, and silently recruited them into a botnet [5]. The attack reached a peak traffic rate of 1.2 terabits per second, making it one of the largest DDoS attacks ever recorded at that time.

Case Study: Mirai → Dyn, 21 October 2016

Beginning at 7 a.m., the botnet was commanded to send tens of millions of requests to Dyn's systems, overwhelming its infrastructure. Over 50 major internet platforms that depended on Dyn for DNS resolution — including PayPal, Twitter, Reddit, Sony, Amazon, Netflix, Spotify, Pinterest, SoundCloud, and Squarespace — became temporarily inaccessible across the Northeastern United States and parts of Europe [6]. The incident demonstrated two critical lessons: consumer IoT devices deployed with no meaningful security hardening can be weaponized at massive scale, and targeting a shared DNS provider rather than a single website can cause cascading disruption across dozens of unrelated organizations simultaneously.

2.3 Recent Escalation (2024–2025 Data)

DDoS attack scale has continued to escalate sharply. According to Cloudflare's quarterly threat reports:

- A 5.6 Tbps attack was recorded in late 2024, lasting approximately 80 seconds [7].
- In May 2025, Cloudflare mitigated a 7.3 Tbps attack, then an 11.5 Tbps attack on 1 September 2025, and finally a 22.2 Tbps attack on 23 September 2025 — at the time, the largest ever recorded, delivered by over 404,000 source IP addresses in just 40 seconds [8].
- By Q4 2025, a campaign dubbed the “Aisuru-Kimwolf” botnet drove a record 31.4 Tbps attack and follow-on application-layer floods exceeding 200 million requests per second [9].
- Across all of 2025, DDoS attack volume on the Cloudflare network rose 121% year-over-year [9].

This trend reflects two converging factors widely cited in current threat-intelligence literature: the continued proliferation of poorly secured IoT devices, and the increasing accessibility of “DDoS-as-a-Service” offerings that allow attackers with minimal technical skill to rent botnet capacity [10].

2.4 Impact

The impact of DoS/DDoS attacks is primarily measured along four dimensions:

- Service downtime and revenue loss — e-commerce, gaming, and financial platforms suffer direct revenue loss for every minute of unavailability.
- Reputational damage — repeated outages erode customer trust.
- Operational cost — incident response, forensic investigation, and emergency mitigation services carry significant direct cost.

- Diversionary cover — DDoS attacks are sometimes used as a smokescreen to distract security teams while a separate, quieter intrusion (e.g., data exfiltration) is carried out elsewhere in the network.

2.5 Mitigation Strategies

Mitigation	Description
Cloud-based DDoS protection	Scrubbing services (Cloudflare, Akamai, AWS Shield) absorb and filter volumetric traffic before it reaches origin servers.
Rate limiting / throttling	Limits the number of requests or connections accepted from a single source within a time window.
SYN cookies / SYN proxying	Avoids allocating full connection state until the handshake is verified, defeating SYN floods.
Anycast network architecture	Distributes incoming traffic across many geographically dispersed points of presence so no single node is overwhelmed [11].
Network redundancy / failover	Ensures traffic can be rerouted if one data center or link is saturated.
Ingress/egress filtering (BCP 38)	Prevents spoofed-source packets from leaving or entering a network, reducing reflection/amplification attack effectiveness.
IoT device hardening	Changing default credentials and disabling unused remote-management services prevents botnet recruitment (e.g., Mirai).

3. Man-in-the-Middle (MITM) Attacks

3.1 Definition and Mechanism

A man-in-the-middle (MITM) attack, also called an on-path attack, is a cyberattack in which the attacker secretly relays and possibly alters communications between two parties who believe they are communicating directly with each other. The attacker effectively inserts themselves into the communication channel, gaining the ability to eavesdrop, steal credentials, inject malicious content, or alter transactions in real time, all while both legitimate parties remain unaware [12].

MITM attacks can occur at multiple layers of the network stack. Common techniques include:

- ARP spoofing — sends fake ARP messages to associate the attacker's MAC address with a target IP, intercepting local network traffic.
- DNS spoofing — redirects DNS queries to malicious servers.
- SSL/TLS stripping — downgrades an HTTPS connection to unencrypted HTTP.
- HTTPS spoofing — substitutes a fraudulent SSL/TLS certificate.
- Session hijacking — steals session cookies or tokens to impersonate an authenticated user.
- Rogue Wi-Fi access points (“evil twin”) — create a fake hotspot to intercept traffic from connected devices.

3.2 ARP Spoofing as a Foundational MITM Technique

ARP (Address Resolution Protocol) spoofing deserves particular attention because it is the most common technique for executing a MITM attack on a local area network (LAN). It is an attack in which an attacker impersonates another device by sending falsified ARP messages in order to intercept network traffic between a user and, for example, the network gateway, allowing the attacker to eavesdrop on, modify, or block transmitted data.

In practical terms: when a network participant wants to establish a connection to a server, it first checks its ARP table to see whether a MAC address is stored for that server's IP address. Since every IP address in the spoofed client's ARP table has been made to point to the attacker's MAC address, the connection is established with the attacker instead of the legitimate server, and the attacker can then read and potentially manipulate the traffic by acting as a transparent proxy [13].

Illustrative Scenario: Public Wi-Fi Credential Theft

ARP spoofing is most likely to succeed against users of public Wi-Fi hotspots, where the attacker and victim share the same local network segment. A common scenario: a public location offers free Wi-Fi through a router that has been compromised with malicious software; when a user on that network logs

into a banking website, their credentials can be captured by the attacker positioned between the user and the legitimate server [17].

3.3 Impact

MITM attacks are typically used to collect personal credentials and login information, and may be used to deliver a compromised software update containing malware; unencrypted communication sent over insecure network connections is especially vulnerable. Beyond direct credential theft, MITM attacks have been used to manipulate financial transactions, harvest session tokens to bypass authentication entirely, and, in more sophisticated state-level operations, to conduct long-term espionage against government and corporate targets through compromised DNS or network infrastructure (see Section 4.3).

3.4 Mitigation Strategies

Mitigation	Description
Strong end-to-end encryption	TLS/SSL, SSH, and VPN ensure that even intercepted traffic remains unreadable to the attacker.
HSTS	HTTP Strict Transport Security prevents SSL/TLS-stripping downgrade attacks by forcing browsers to use HTTPS only.
Dynamic ARP Inspection (DAI) / Port Security	Switch-level features that block forged ARP packets on managed network switches.
Static ARP entries	In small, controlled networks, hard-coding trusted IP-to-MAC mappings prevents ARP cache poisoning.
Continuous network monitoring	Detects anomalies such as duplicated MAC addresses or unusual ARP traffic volume in real time.
Certificate pinning/validation	Detects fraudulent or substituted SSL/TLS certificates used in HTTPS spoofing.
VPN on public networks	Prevents an on-path attacker on the same hotspot from reading traffic.
Multi-factor authentication (MFA)	Limits the damage of stolen credentials, since a password alone no longer suffices to authenticate.

4. Spoofing Attacks

Spoofing is the broad technique of falsifying data to impersonate another device, user, or system, with the goal of gaining unauthorized access, bypassing security controls, or rerouting traffic. Spoofing is not a single attack but rather an enabling technique that underlies many DoS and MITM attacks described above [14]. This section examines the three most common forms: IP spoofing, ARP spoofing, and DNS spoofing.

4.1 IP Spoofing

IP spoofing involves forging the source IP address field in a packet's header so that it appears to originate from a trusted or different host. It is used for two main purposes: (1) to hide the true origin of an attacker's traffic, and (2) to enable reflection/amplification DDoS attacks, in which the attacker sends requests to a third-party server with the victim's IP address spoofed as the source, causing the third party to flood the victim with response traffic the victim never requested. DNS amplification attacks, mentioned in Section 2.3, rely on exactly this technique.

4.2 ARP Spoofing

ARP spoofing (covered in detail in Section 3.2) is fundamentally a Local Area Network spoofing technique. It is not considered very dangerous on its own, because it requires the attacker to be connected to the same local network as the victim; to be useful as part of a MITM attack on web traffic, it typically must be combined with other techniques such as SSL stripping or SSL hijacking. Despite this limitation, it remains extremely common in practice because so many networks, particularly public and small-office/home networks, lack switch-level protections such as Dynamic ARP Inspection.

4.3 DNS Spoofing (DNS Cache Poisoning)

DNS spoofing, also called DNS cache poisoning, exploits the fact that DNS queries and responses are typically sent unencrypted over UDP, and DNS's original design prioritizes speed and reliability over built-in authentication and confidentiality, making it relatively easy for attackers to spoof responses or eavesdrop on queries. When an attacker successfully injects a forged DNS response before the legitimate authoritative server's response arrives, the DNS resolver stores that incorrect answer in its cache for future use [18].

Case Study: DNSpionage and Sea Turtle (2018–2019)

Between late 2018 and 2019, two separate campaigns — DNSpionage and Sea Turtle — targeted DNS infrastructure across the Middle East, North Africa, and parts of Europe. DNSpionage compromised DNS records belonging to government agencies and companies, redirecting traffic through attacker-controlled infrastructure where credentials were harvested mid-transit, while Sea Turtle went further by directly compromising DNS registrars and service providers to redirect targets to attacker-controlled nameservers.

In response, the U.S. Cybersecurity and Infrastructure Security Agency (CISA) issued Emergency Directive 19-01, requiring federal agencies to audit DNS records, enforce multi-factor authentication on registrar accounts, and monitor for unauthorized changes [19].

This case illustrates that DNS spoofing in practice often goes beyond simple cache poisoning and extends into the compromise of the registrar and provider infrastructure itself — a distinction with direct implications for which defenses are effective, as shown below.

4.4 Mitigation Strategies for Spoofing

Mitigation	Applies To	Description
DNSSEC	DNS spoofing	Uses public-key cryptography to validate that DNS responses originate from the correct authoritative server and have not been tampered with; recommended by ICANN and incorporated into NIST SP 800-53.
Registrar-level account hardening	DNS spoofing (registrar hijacking)	DNSSEC mitigates resolver-level cache poisoning on signed zones but does not protect against registrar hijacking, BGP rerouting, DHCP spoofing, or hosts-file manipulation (NIST SP 800-44v2).
Dynamic ARP Inspection / Port Security	ARP spoofing	Switch-level filtering of forged ARP packets, as discussed in Section 3.4.
Ingress/egress filtering (BCP 38 / RFC 2827)	IP spoofing	ISPs and network operators verify that outbound packet source addresses match the assigned address range.
Anti-spoofing controls (NIST SC-16(2))	General spoofing	Requires organizations to implement mechanisms that prevent falsification of security attributes and detect alteration of security process indicators.
DMARC, SPF, DKIM	Email spoofing (related vector)	A robust DMARC deployment satisfies requirements across MITRE ATT&CK mitigations, NIST email security controls, and regulatory mandates [20].

5. Comparative Analysis

Aspect	DoS / DDoS	Man-in-the-Middle	Spoofing
Security goal violated	Availability	Confidentiality & Integrity	Authenticity (precursor to others)
Attacker position	Remote, often distributed globally	Same segment or on-path infrastructure	Same segment (ARP) or remote (DNS/IP)
Detectability	Usually obvious (outage)	Often invisible until damage found	Varies by type
Primary motive	Disruption, extortion, hacktivism	Credential theft, espionage, fraud	Enables DoS, MITM, or impersonation
Representative case	Mirai/Dyn (2016); 31.4 Tbps (2025)	Public Wi-Fi credential theft	DNSpionage/Sea Turtle (2018–2019)
Core defensive principle	Absorb, filter, distribute load	Encrypt and authenticate every hop	Verify identity at protocol level

A key analytical observation is that these three categories are not mutually exclusive. Spoofing is frequently the mechanism that enables both DoS attacks (IP spoofing in reflection attacks) and MITM attacks (ARP/DNS spoofing as the entry technique). A mature network security posture must therefore address all three simultaneously rather than treating them as independent problems.

6. General Best Practices for Network Security

Drawing on the mitigation strategies discussed above, the following represents a consolidated, layered defense framework:

- 1. Encrypt everything in transit.** TLS for web traffic, SSH for remote administration, VPNs for remote access, and WPA3 for wireless networks.
- 2. Authenticate at the protocol level.** Deploy DNSSEC, enforce certificate validation, and adopt DMARC/SPF/DKIM for email.
- 3. Segment and monitor the network.** Use VLANs, Dynamic ARP Inspection, and continuous traffic monitoring/IDS-IPS systems to catch anomalies early.
- 4. Harden endpoints and IoT devices.** Change default credentials, apply firmware updates, and disable unused services to prevent botnet recruitment.
- 5. Plan for availability under attack.** Use cloud-based DDoS scrubbing, anycast architecture, and redundant infrastructure.

6. Enforce least privilege and MFA. Reduce the value of any single stolen credential.

7. Maintain incident response and audit capability. Log network activity, audit DNS records/registrar accounts, and rehearse incident response plans.

8. Educate users. Security awareness training remains critical since many attacks succeed via untrusted networks or ignored certificate warnings.

7. Conclusion

Denial-of-Service attacks, Man-in-the-Middle attacks, and spoofing attacks represent three of the most persistent and consequential categories of network security threats, and as the evidence in this report demonstrates, their scale and sophistication continue to grow year over year.

The 2016 Mirai/Dyn incident and the record-breaking 2025 Cloudflare-mitigated attacks illustrate that volumetric availability attacks have moved from a theoretical risk to a routine, almost daily operational reality for major service providers. Similarly, MITM and spoofing techniques, particularly ARP spoofing on local networks and DNS infrastructure compromise at a larger scale, continue to provide attackers with reliable means of intercepting and manipulating trust relationships that most network protocols were never designed to authenticate.

No single control eliminates these risks. Effective defense requires a layered combination of cryptographic protocols (TLS, DNSSEC), network-level controls (Dynamic ARP Inspection, ingress/egress filtering, anycast routing), cloud-based traffic scrubbing, and sustained organizational discipline around credential hygiene, patching, and monitoring.

As IoT adoption and reliance on cloud-based DNS and CDN infrastructure both continue to expand, the attack surface for all three threat categories is likely to grow further, making continuous investment in layered, standards-based defense (e.g., NIST SP 800-53, DNSSEC, BCP 38) an organizational necessity rather than an optional best practice.

8. References

This report synthesizes information from the following sources, consulted in June 2026 for academic research purposes. All statistics and technical descriptions are attributed to their original source; content is paraphrased in the author's own words in accordance with academic integrity and copyright standards.

- [1] Cloudflare. 2025 Q4 DDoS Threat Report: A Record-Setting 31.4 Tbps Attack Caps a Year of Massive DDoS Assaults. Cloudflare Blog, 2026.
- [2] Wikipedia contributors. Denial-of-service attack. Wikipedia, The Free Encyclopedia, 2026.
- [3] DeepStrike. DDoS Attack Statistics: 20.5M Attacks Blocked in Q1 2025. 2025.
- [4] Various authors. Review of SYN-Flooding Attack Detection Mechanism. arXiv preprint.
- [5] Cloudflare. What is the Mirai Botnet? Cloudflare Learning Center.
- [6] CoverLink Insurance. Cyber Case Study: The Mirai DDoS Attack on Dyn. 2022.
- [7] ExpertInsights. DDoS Attacks in 2025: A Deep Dive into the Latest Stats & Threat Trends. 2025.
- [8] Wikipedia contributors. Denial-of-service attack (22.2 Tbps record attack, September 2025).
- [9] Cloudflare. 2025 Q4 DDoS Threat Report (Aisuru-Kimwolf botnet campaign, 31.4 Tbps record attack).
- [10] StormWall. Global DDoS Attack Statistics: Q1 2025 Report. 2025.
- [11] ControlD. The 6 Major Types of DNS Attacks and How to Prevent Them. 2025.
- [12] Fortinet. What Is a Man-in-the-Middle (MITM) Attack? Types & Examples. Fortinet Cyberglossary.
- [13] Wikipedia contributors. Man-in-the-middle attack. Wikipedia, The Free Encyclopedia, 2026.
- [14] ProSec GmbH. ARP Spoofing | Man in the Middle Attack. ProSec Networks Blog.
- [15] Sycope. ARP Spoofing — How to Detect a Man-in-the-Middle Attack and ARP Poisoning in a LAN Network. 2026.
- [16] Invicti. ARP Spoofing. Invicti Learn.
- [17] Various authors. A Review of Man-in-the-Middle Attacks. arXiv preprint.
- [18] BlueCat Networks. What is DNS Poisoning (DNS Spoofing) and How to Prevent It. 2025.
- [19] Abnormal AI. DNS Cache Poisoning & Spoofing: How It Works (DNSpionage and Sea Turtle case study; CISA Emergency Directive 19-01). 2026.
- [20] Vectra AI. Spoofing Attack Explained: 8 Types, Detection & Defense. 2026.
- [21] National Institute of Standards and Technology (NIST). NIST SP 800-53 and NIST SP 800-44v2 — referenced via secondary sources [18, 19] for DNSSEC and DNS security guidance.

Methodology note: This report was compiled using current industry threat-intelligence publications (Cloudflare, Fortinet, StormWall, ExpertInsights), peer-reviewed and preprint academic literature (arXiv), encyclopedic technical references (Wikipedia, cross-checked against primary sources), and vendor/security-community documentation (Invicti, ProSec, Sycope, BlueCat, Abnormal AI, Vectra AI). All sources were accessed in June 2026.
